Constant Segrétain

Procédure de mise en service d'un poste Windows

Trois variantes selon le tier d'administration — T2, T1, T0

Syndicat Mixte d'Eau et d'Assainissement du Val-de-Loire (SMEA)

BTS SIO 2e année · option SISR · Bloc U7 — Sécurisation d'une infrastructure

MDS Angers · P. BRIAND · 2026-2027

1. Objet et périmètre

Ce document décrit la procédure de mise en service des postes de travail Windows du SMEA, en trois variantes correspondant aux trois tiers du modèle d'administration à privilèges (T0, T1, T2). Chaque étape doit pouvoir être appliquée par un technicien sans connaissance préalable du contexte, dans l'ordre indiqué, avec preuve de vérification à l'appui.

Le tier attribué à un poste dépend de ce qu'un attaquant obtiendrait en le compromettant, pas de l'importance de la personne. La variante T2 est rédigée intégralement et appliquée sur un banc de test réel ; T1 et T0 sont documentées en écart par rapport à T2.

Banc de test : VM Windows Server 2022 Standard — Expérience utilisateur de bureau, sous VirtualBox (4 Go RAM, 2 vCPU, 60 Go disque, réseau NAT). Deux instantanés : etat-initial (après installation) et apres-audit (avant première modification).

2. Attribution des trois postes aux trois tiers

Q0.1 — Attribution et justification

Personne	Tier	Ce que la compromission permettrait de prendre
Nadia B. — comptable	T2	Aucun droit d'administration ; accès à des données financières et au portail de trésorerie, mais aucune prise sur l'infrastructure.
Karim T. — administrateur systèmes	T1	Comptes d'administration sur ~15 serveurs métier (fichiers, GED, facturation) ; pivot direct vers ces serveurs, sans atteindre le cœur du domaine.
Élodie R. — responsable DSI	T0	Comptes d'administration des DC, de l'AC interne, du cluster d'hyperviseurs et de la sauvegarde ; contrôle total du SI.

Q0.2 — Pratiques qui annulent le modèle de tiers

- Karim : même poste pour administrer des serveurs T1 et pour messagerie/navigation — un document piégé suffit à capturer les identifiants serveur.
- Élodie : messagerie relevée « depuis n'importe où » avec le compte qui contrôle tout le SI — version la plus grave du même problème (phishing, wifi public, vol de portable).

Principe violé dans les deux cas : un identifiant de niveau N ne doit jamais être exposé à un usage de risque inférieur à N. Le tiering est une question d'étanchéité des usages, pas de robustesse du poste.

3. État initial constaté sur la machine de test

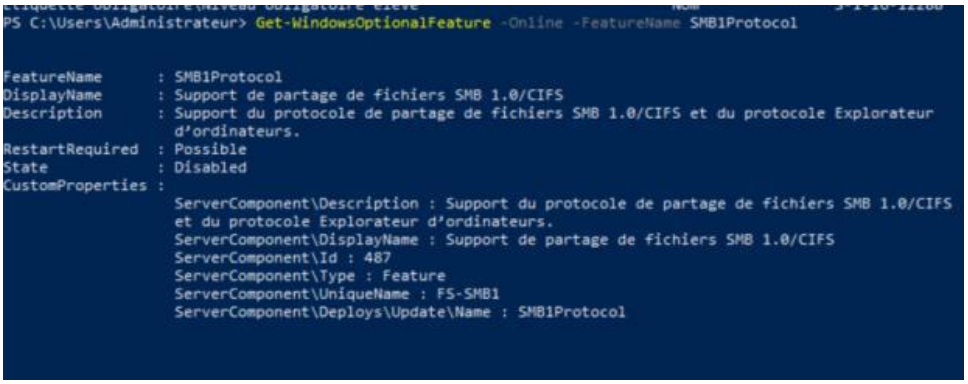
Relevé en PowerShell administrateur, juste après installation (instantané etat-initial), figé par l'instantané apres-audit.

#	Point de contrôle	Valeur constatée	Écart
1	SMBv1	State: Disabled (absent par défaut)	Conforme
2	Mdp / verrouillage	minpwlen=7, max=42j, historique=24, seuil verrouillage=Jamais	Écart (longueur < 14, aucun verrouillage)
3	Comptes locaux	Administrateur: Enabled=True — Invité: Enabled=False — « Admin » présent, non documenté	Écart (compte intégré actif + compte non tracé)
4	Groupe Administrateurs (SID S-1-5-32-544)	Admin, Administrateur, Admins de l'entreprise, Admins du domaine	Écart (groupe surchargé, groupes de domaine à vérifier)
5	LmCompatibilityLevel	Non défini (niveau 3 implicite)	Écart (niveau 5 attendu)

#	Point de contrôle	Valeur constatée	Écart
6	Pare-feu (3 profils)	Enabled=True — action entrante NotConfigured — logs désactivés	Écart (action/log non figés)
7	Stratégie d'audit	Quelques sous-catégories seulement (ouverture de session)	Écart (audit très partiel)
8	Ports en écoute	53, 88, 135, 445, 464, 593, 636, 3260, 3269, 3389, 5357, 5985, 9389, 47001 + ports dynamiques (49664-49669, 53748, 55693, 63755, 63756, 63761)	Écart (DNS, RDP, WinRM, ADWS, LDAP/LDAPS exposés)
9	Fonctionnalités installées	DNS, AD DS, Services de fichiers/iSCSI, RSAT, Defender, PowerShell	Écart majeur (empreinte de serveur)
10	Bureau à distance	fDenyTSConnections = 0 (autorisé)	Écart (RDP ouvert)

Captures réelles — état initial (Partie B)

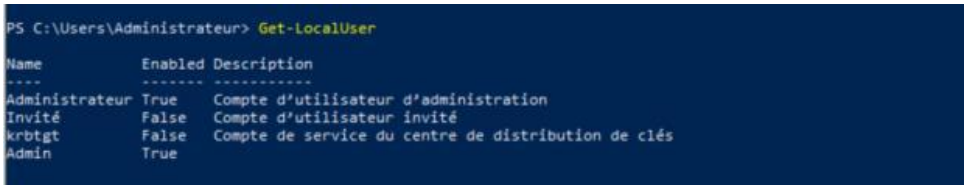
Sorties effectivement obtenues sur le banc de test, à l'appui du tableau ci-dessus.



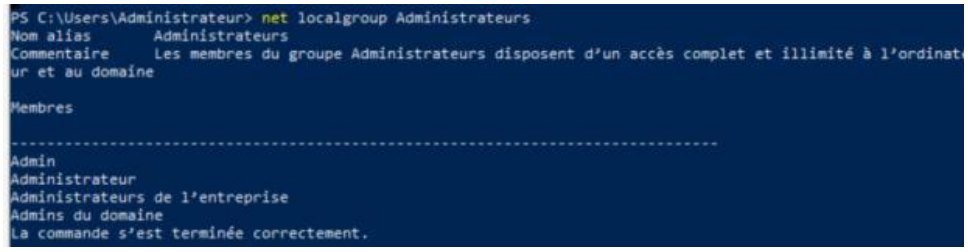
Point 1 — Get-WindowsOptionalFeature SMB1Protocol → State: Disabled



Point 2 — net accounts → minpwlen=7, seuil de verrouillage: Jamais

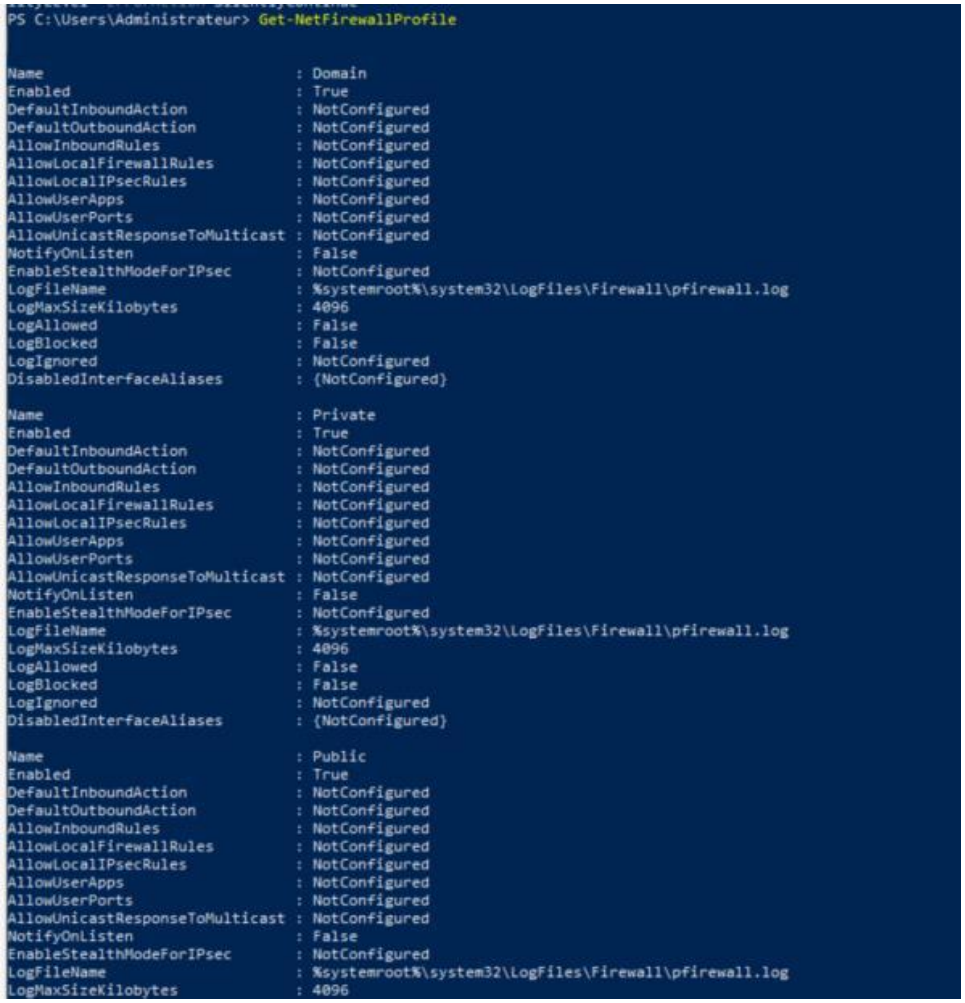


Point 3 — Get-LocalUser → Administrateur/Admin actifs, Invité désactivé



Point 4 — net localgroup Administrateurs → Admin, Administrateur, groupes de domaine

Constant Segrétain

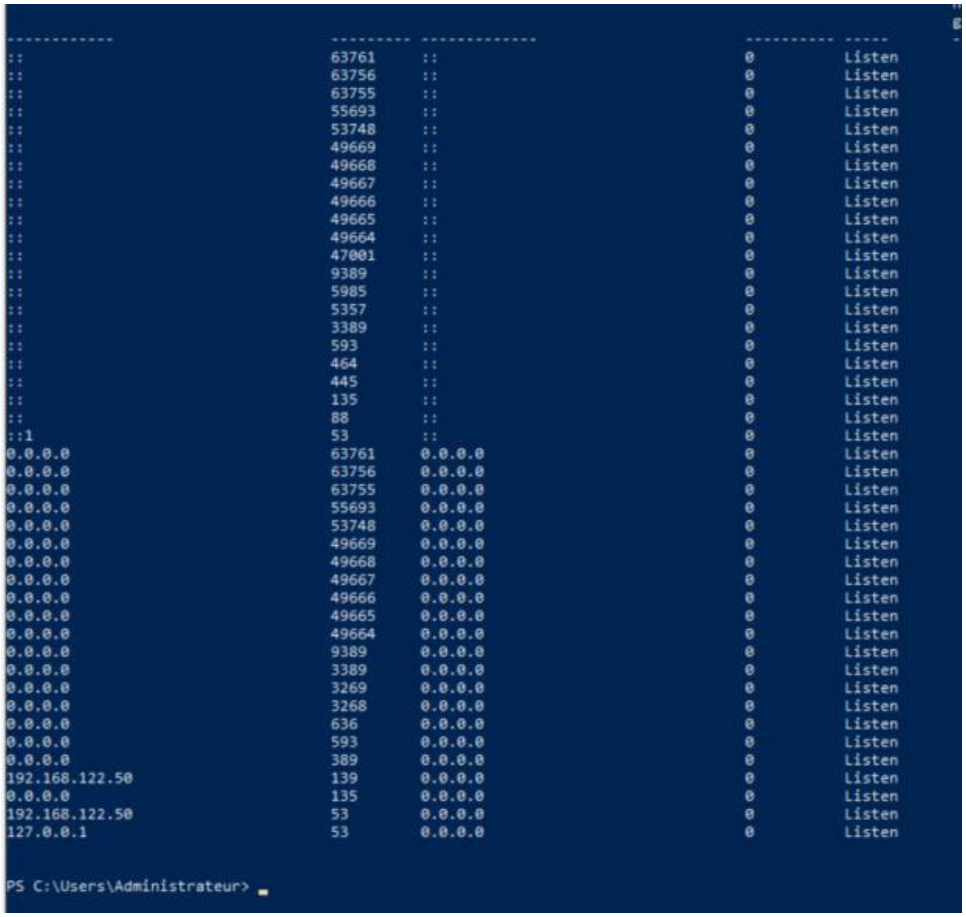


Point 6 — Get-NetFirewallProfile → DefaultInboundAction NotConfigured, logs désactivés

Constant Segrétain

```
PS C:\Users\Administrateur> auditpol /get /category:*
Stratégie d'audit système
Catégorie/Sous-catégorie                    Paramètre
Système
  Extension système de sécurité            Pas d'audit
  Intégrité du système                     Succès et échec
  Pilote IPSEC                             Pas d'audit
  Autres événements système                Succès et échec
  Modification de l'état de la sécurité    Réussite
Ouverture/Fermeture de session
  Ouvrir la session                        Succès et échec
  Fermer la session                        Réussite
  Verrouillage du compte                   Réussite
  Mode principal IPsec                     Pas d'audit
  Mode rapide IPsec                        Pas d'audit
  Mode étendu IPsec                        Pas d'audit
  Ouverture de session spéciale            Réussite
  Autres événements d'ouverture/fermeture de sessionPas d'audit
  Serveur NPS                              Succès et échec
  Revendications utilisateur/de périphériquePas d'audit
  Appartenance à un groupe                 Pas d'audit
Accès aux objets
  Système de fichiers                      Pas d'audit
  Registre                                 Pas d'audit
  Objet de noyau                           Pas d'audit
  SAM                                      Pas d'audit
  Services de certification                Pas d'audit
  Généré par application                   Pas d'audit
  Manipulation de handle                   Pas d'audit
  Partage de fichiers                      Pas d'audit
  Rejet de paquet par la plateforme de filtragePas d'audit
  Connexion de la plateforme de filtrage   Pas d'audit
  Autres événements d'accès à l'objet      Pas d'audit
  Partage de fichiers détaillé             Pas d'audit
  Stockage amovible                        Pas d'audit
  Stratégie centralisée intermédiaire      Pas d'audit
Utilisation de privilège
  Utilisation de privilèges non sensibles Pas d'audit
  Autres événements d'utilisation de privilègesPas d'audit
  Utilisation de privilèges sensibles      Pas d'audit
Suivi détaillé
  Création du processus                    Pas d'audit
  Fin du processus                         Pas d'audit
  Activité DPAPI                           Pas d'audit
  Événements RPC                           Pas d'audit
  Événements Plug-and-Play                 Pas d'audit
  Événements de jeton ajustés à droite     Pas d'audit
Changement de stratégie
  Modification de la stratégie d'audit     Réussite
  Modification de la stratégie d'authentificationRéussite
  Modification de la stratégie d'autorisationPas d'audit
  Modification de la stratégie de niveau règle MPSSVCPas d'audit
  Modification de la stratégie de plateforme de filtragePas d'audit
  Autres événements de modification de stratégiePas d'audit
Gestion des comptes
```

Point 7 — auditpol /get /category: → audit très partiel*



```
                                                
```

4. Procédure T2 complète — poste de Nadia B.

Version réduite à 10 étapes (sur les 20 initiales de la procédure complète), retenues pour leur simplicité de mise en œuvre : une ou deux commandes, aucun prérequis d'infrastructure absente du banc de test, pas de chaîne de dépendance à risque. Étapes écartées de cette version : 03 (désactivation du compte intégré — point de rupture), 05 (LAPS — nécessite un contrôleur de domaine), 11 (audit — plusieurs catégories à activer), 13 et 14 (retrait de rôles et Bureau à distance/WinRM — plus de commandes, risque sur le spouleur), 15 à 17 (AppLocker — chaîne à trois étapes avec point de rupture), 18 (BitLocker — nécessite un TPM absent de la VM), 19 (mises à jour — contrôle de conformité plutôt qu'action de durcissement).

État d'avancement réel sur la VM de test

Les commandes effectivement exécutées à ce stade sur la VM ne suivent pas exactement la numérotation ci-dessous (une liste de travail antérieure, à 10 étapes, a été utilisée). Correspondance avec les 16 domaines requis :

Domaine requis	État réel constaté	Action avant validation
1 — Compte Administrateur intégré	⚠ Fait, mais en une seule commande (création + désactivation combinées) au lieu de 01→02→03 séparées.	Revérifier que AdminSMEA ouvre bien une session et s'élève AVANT toute nouvelle désactivation ailleurs — l'ordre séparé est une exigence du sujet, pas une formalité.
2 — Compte Invité	✅ Fait (Disable-LocalUser Invité).	Aucune.
3 — Mot de passe admin local unique (LAPS)	❌ Non fait.	À exécuter (non applicable telle quelle sur VM isolée — cf. Q C.1).
4 — Politique de mots de passe	⚠ Partiel : minpwlen:14 seul appliqué.	Compléter avec /maxpwage:90 /uniquepw:5 (étape 06).
5 — Verrouillage de compte	❌ Non fait.	À exécuter (étape 07).
6 — SMBv1	✅ Fait (déjà conforme par défaut).	Aucune.
7 — LAN Manager (LM/NTLMv1)	❌ Non fait.	À exécuter (étape 09).
8 — Pare-feu	⚠ Partiel : blocage entrant activé, journalisation non activée.	Ajouter -LogBlocked True -LogMaxSizeKilobytes 16384 (étape 10).
9 — Stratégie d'audit	⚠ Partiel : seule la catégorie « Ouverture/Fermeture de session » activée.	Ajouter Gestion des comptes, Accès aux objets, Changement de stratégie (étape 11).
10 — UAC	✅ Fait.	Aucune.
11 — Fonctionnalités/services inutiles	❌ Erreur : le spouleur d'impression a été désactivé.	⚠ À corriger : réactiver le spouleur (Nadia scanne/imprime) et appliquer la mitigation PrintNightmare à la place (étape 13). Les rôles serveur (DNS, AD DS, fichiers/iSCSI) restent à retirer.
12 — Bureau à distance/admin distante	⚠ Partiel : RDP fermé, WinRM non traité.	Ajouter Disable-PSRemoting -Force et Set-Service WinRM -StartupType Disabled (étape 14).
13 — Restriction d'exécution (AppLocker)	❌ Non fait.	À exécuter (étapes 15-17, dans l'ordre).
14 — Chiffrement disque (BitLocker)	❌ Non fait.	Non applicable sur cette VM sans TPM — documenter en Q C.1, ne pas tenter.
15 — Mises à jour de sécurité	❌ Non fait.	À documenter (étape 19).
16 — Compte utilisateur final	❌ Non fait.	À exécuter (étape 20) — nécessaire pour la recette finale.

Le point le plus important à corriger avant de continuer : le spouleur d'impression a été désactivé alors que le sujet demande explicitement de le conserver pour Nadia (numérisation de pièces justificatives) et d'appliquer la mitigation PrintNightmare à la place. Le retirer purement et simplement casserait un usage métier réel — c'est le genre d'erreur qu'un audit relèverait.

Étape 1 — Créer un compte administrateur nominatif (Domaine 1)

Constant Segrétain

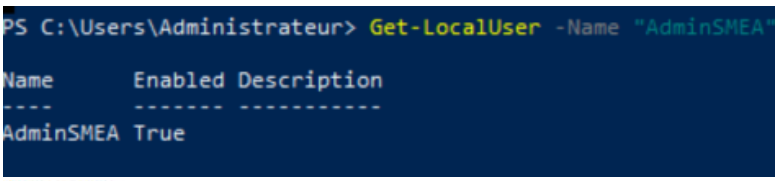
Tiers : T2 · T1 · T0

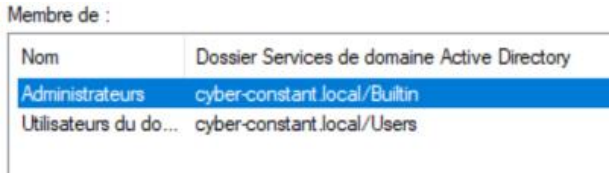
Pourquoi : Il faut un compte de secours vérifié avant de désactiver le compte intégré, sous peine de perte d'accès définitive. (Réf. CIS 2.3.1.1)

Commande :

```
New-LocalUser -Name "AdminSMEA" -Password (ConvertTo-SecureString "MotDePasseComplexe!" -AsPlainText -Force)
Add-LocalGroupMember -Group "Administrateurs" -Member "AdminSMEA"
```

Vérification : `Get-LocalUser -Name "AdminSMEA"` → `Enabled=True` ; `Get-LocalGroupMember -SID S-1-5-32-544` → liste AdminSMEA





Impact : Aucune interruption ; ajoute un second compte admin, le compte intégré reste actif à ce stade.

Étape 2 — Vérifier l'ouverture de session et l'élévation (Domaine 1)

Tiers : T2 · T1 · T0 ⚠ *Prérequis : étape 01 validée.*

Pourquoi : Une création non vérifiée n'est qu'une hypothèse ; il faut confirmer que le compte de secours fonctionne avant de couper le compte intégré.

Commande :

```
# Nouvelle session AdminSMEA → PowerShell admin (UAC accepté)
whoami /groups
```

Vérification : `BUILTIN\Administrateurs doit apparaître avec l'attribut « Groupe habilité »`

Impact : Aucune modification, contrôle pur.

Étape 4 — Désactiver le compte Invité (Domaine 2)

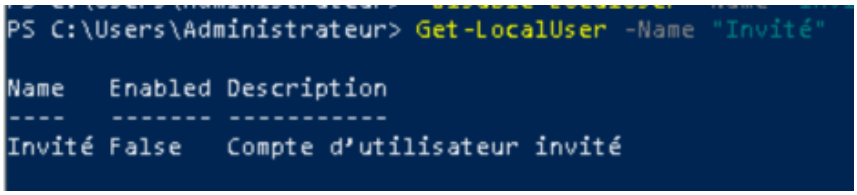
Tiers : T2 · T1 · T0

Pourquoi : Un compte non authentifié actif enfreint le moindre privilège et facilite la reconnaissance réseau. (Réf. CIS 2.3.1.2)

Commande :

```
Disable-LocalUser -Name "Invité"
```

Vérification : `Get-LocalUser -Name "Invité"` → `Enabled=False`



Impact : Aucune session sans compte nominatif.

Étape 6 — Politique de mots de passe (Domaine 4)

Tiers : T2 · T1 · T0

Pourquoi : L'état initial (longueur mini 7) est vulnérable aux attaques par dictionnaire. (Réf. CIS 1.1.4)

Commande :

```
net accounts /minpwlen:14 /maxpwage:90 /uniquepw:5
```

Vérification : `net accounts` → « Longueur minimale du mot de passe : 14 »

```
PS C:\Users\Administrateur> net accounts /minpwlen:14 /maxpwage:90 /uniquepw:5
La commande s'est terminée correctement.

PS C:\Users\Administrateur> net accounts
Fermeture forcée de la session après expiration ? :                  Jamais
Durée de vie minimale du mot de passe (jours) :                      1
Durée de vie maximale du mot de passe (jours) :                      90
Longueur minimale du mot de passe :                                  14
Nombre de mots de passe antérieurs à conserver :                     5
Seuil de verrouillage :                                              Jamais
Durée du verrouillage (min) :                                        30
Fenêtre d'observation du verrouillage (min) :                        30
Rôle de l'ordinateur :                                               PRINCIPAL
La commande s'est terminée correctement.
```

Impact : Mots de passe/phrases longues au prochain renouvellement.

Étape 7 — Configurer le verrouillage de compte (Domaine 5)

Tiers : T2 · T1 · T0

Pourquoi : Seuil « Jamais » en état initial → force brute en ligne illimitée. (Réf. CIS 1.2.1-1.2.3)

Commande :

`net accounts /lockoutthreshold:5 /lockoutduration:15 /lockoutwindow:15`

Vérification : `net accounts` → « Seuil de verrouillage : 5 »

```
PS C:\Users\Administrateur> net accounts /lockoutthreshold:5 /lockoutduration:15 /lockoutwindow:15
La commande s'est terminée correctement.

PS C:\Users\Administrateur> net accounts
Fermeture forcée de la session après expiration ? :                  Jamais
Durée de vie minimale du mot de passe (jours) :                      1
Durée de vie maximale du mot de passe (jours) :                      90
Longueur minimale du mot de passe :                                  14
Nombre de mots de passe antérieurs à conserver :                     5
Seuil de verrouillage :                                              5
Durée du verrouillage (min) :                                        15
Fenêtre d'observation du verrouillage (min) :                        15
Rôle de l'ordinateur :                                               PRINCIPAL
La commande s'est terminée correctement.
```

Impact : Blocage 15 min après 5 échecs.

Étape 8 — Désactiver le protocole SMBv1 (Domaine 6)

Tiers : T2 · T1 · T0

Pourquoi : Protocole obsolète, vecteur de ransomwares (WannaCry/EternalBlue). (Réf. CIS 18.3.x)

Commande :

`Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart`

Vérification : `Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol` → `Disabled` (déjà conforme sur cette VM ; étape maintenue par principe)

```
PS C:\Users\Administrateur> Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart


Path          :
Online        : True
RestartNeeded : False



PS C:\Users\Administrateur> Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol


FeatureName      : SMB1Protocol
DisplayName      : Support de partage de fichiers SMB 1.0/CIFS
Description      : Support du protocole de partage de fichiers SMB 1.0/CIFS et du protocole Explorateur
                   d'ordinateurs.
RestartRequired  : Possible
State            : Disabled
CustomProperties :
                   ServerComponent\Description : Support du protocole de partage de fichiers SMB
                   1.0/CIFS et du protocole Explorateur d'ordinateurs.
                   ServerComponent\DisplayName : Support de partage de fichiers SMB 1.0/CIFS
                   ServerComponent\Id : 487
                   ServerComponent\Type : Feature
                   ServerComponent\UniqueName : FS-SMB1
                   ServerComponent\Deploys\Update\Name : SMB1Protocol
```

Impact : Équipements très anciens (copieurs/NAS) perdent l'accès aux partages.

Étape 9 — Refuser les authentifications LM et NTLMv1 (Domaine 7)

Tiers : T2 · T1 · T0

Pourquoi : Empreintes cassables hors ligne en quelques heures, capturables sur le réseau. (Réf. CIS 2.3.11.7)

Commande :

```
Set-ItemProperty "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name LmCompatibilityLevel -Value 5 -Type DWord
```

Vérification :

```
Get-ItemProperty "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name LmCompatibilityLevel
```

```
PS C:\Users\Administrateur> Get-ItemProperty "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name LmCompatib
ilityLevel


LmCompatibilityLevel : 5
PSPath               : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Co
                       ntrol\Lsa
PSParentPath         : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Co
                       ntrol
PSChildName          : Lsa
PSDrive              : HKLM
PSProvider           : Microsoft.PowerShell.Core\Registry
```

Impact : Équipements NTLMv1-only ne s'authentifient plus (à vérifier avant application).

Étape 10 — Pare-feu — blocage entrant et journalisation (Domaine 8)

Tiers : T2 · T1 · T0

Pourquoi : Action entrante « NotConfigured » et logs désactivés en état initial → aucune preuve d'attaque bloquée. (Réf. CIS 9.1-9.3)

Commande :

```
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True -DefaultInboundAction Block -DefaultOutboundAction Allow
Set-NetFirewallProfile -Profile Domain,Public,Private -LogBlocked True -LogMaxSizeKilobytes 16384
```

Vérification : `Get-NetFirewallProfile | Select Name,Enabled,DefaultInboundAction,LogBlocked`

```
PS C:\Users\Administrateur> Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True -DefaultIn
boundAction Block -DefaultOutboundAction Allow
>>
>> Set-NetFirewallProfile -Profile Domain,Public,Private -LogBlocked True -LogMaxSizeKilobytes 16384
PS C:\Users\Administrateur>
PS C:\Users\Administrateur> Get-NetFirewallProfile | Select Name,Enabled,DefaultInboundAction,LogBlocked

Name    Enabled DefaultInboundAction LogBlocked
----    ------- -------------------- ----------
Domain     True                Block       True
Private    True                Block       True
Public     True                Block       True
```

Impact : Tout service entrant nécessite une règle explicite ; tentatives bloquées tracées.

Étape 12 — Durcir le contrôle de compte d'utilisateur (UAC) (Domaine 10)

Tiers : T2 · T1 · T0

Pourquoi : Empêche l'exécution silencieuse d'outils avec des droits élevés. (Réf. CIS 2.3.17.1)

Commande :

```
Set-ItemProperty "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" -Name "ConsentPromptBehaviorAdmin" -Value 2
```

Vérification : `Get-ItemProperty (même clé) → ConsentPromptBehaviorAdmin = 2`

```
PS C:\Users\Administrateur> Set-ItemProperty "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Sys
tem" -Name "ConsentPromptBehaviorAdmin" -Value 2
PS C:\Users\Administrateur> Get-ItemProperty "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Sys
tem"


ConsentPromptBehaviorAdmin    : 2
ConsentPromptBehaviorUser     : 3
DelayedDesktopSwitchTimeout   : 0
DisableAutomaticRestartSignOn : 1
DSCAutomationHostEnabled      : 2
EnableCursorSuppression       : 1
EnableFullTrustStartupTasks   : 2
EnableInstallerDetection      : 1
EnableLUA                     : 1
EnableSecureUIAPaths          : 1
EnableUIADesktopToggle        : 0
EnableUwpStartupTasks         : 2
EnableVirtualization          : 1
PromptOnSecureDesktop         : 1
SupportFullTrustStartupTasks  : 1
SupportUwpStartupTasks        : 1
ValidateAdminCodeSignatures   : 0
disablecad                    : 0
dontdisplaylastusername       : 0
legalnoticecaption            :
legalnoticetext               :
scforceoption                 : 0
shutdownwithoutlogon          : 0
undockwithoutlogon            : 1
PSPath                        : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft
                                \Windows\CurrentVersion\Policies\System
PSParentPath                  : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft
                                \Windows\CurrentVersion\Policies
PSChildName                   : System
PSDrive                       : HKLM
PSProvider                    : Microsoft.PowerShell.Core\Registry
```

Impact : Confirmation systématique à chaque élévation.

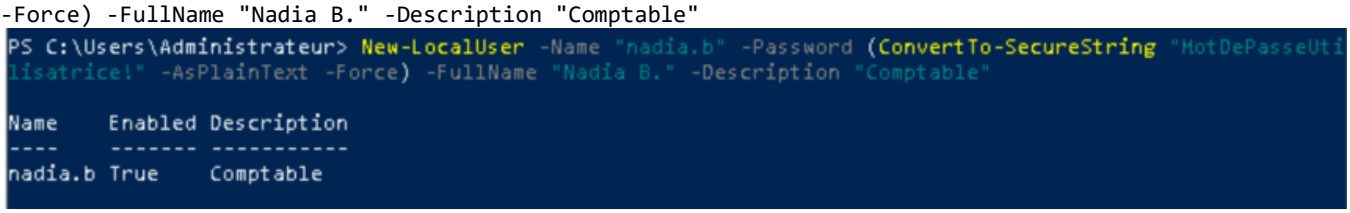
Étape 20 — Créer le compte de l'utilisatrice finale (Domaine 16)

Tiers : T2 · T1 · T0

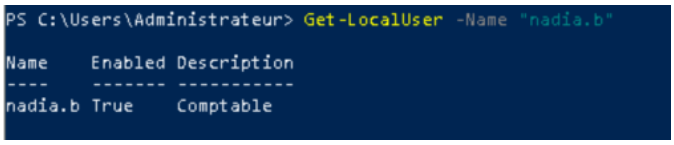
Pourquoi : Nadia doit ouvrir sa session avec son propre compte, sans droit d'administration local — elle n'en a jamais eu besoin. (Réf. CIS 2.3.1 (moindre privilège))

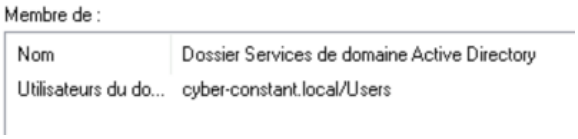
Commande :

```
New-LocalUser -Name "nadia.b" -Password (ConvertTo-SecureString "MotDePasseUtilisatrice!" -AsPlainText -Force) -FullName "Nadia B." -Description "Comptable"
```



Vérification : `"nadia.b" absente de S-1-5-32-544 ; Get-LocalUser -Name "nadia.b" → Enabled=True`





Impact : Droits standard ; toute élévation nécessite AdminSMEA, inconnu de Nadia.

Q C.1 — Étapes non applicables telles quelles sur la VM

- Étape 05 (LAPS) : nécessite un contrôleur de domaine, absent de la VM isolée. Sur un poste réel joint au domaine, la GPO LAPS s'applique normalement une fois le schéma AD étendu.
- Étape 18 (BitLocker) : nécessite un TPM, absent de VirtualBox par défaut. Sur un poste réel équipé d'un TPM 2.0, la commande s'exécute sans adaptation.

Q C.2 — LAPS et désactivation du compte intégré : deux risques distincts

LAPS répond à « le secret est-il unique ? » ; désactiver le compte intégré répond à « cette identité peut-elle encore s'authentifier ? ». Même avec un secret fort, le SID connu (S-1-5-32-544) reste une cible (force brute, relais NTLM). LAPS protège le secret ; la désactivation supprime la cible elle-même — les deux mesures ne sont donc pas redondantes.

Q C.3 — Deux dépendances d'ordre

- 01→02→03 : inversées, une désactivation prématurée du compte intégré peut faire perdre tout accès administrateur — définitivement sur cette VM sans DC.
- 15→16→17 : bloquer avant d'avoir les règles rend la machine inutilisable (plus rien ne se lance, pas même PowerShell) ; activer le blocage sans le service actif donne une fausse impression de protection.

Q C.4 — La question de l'édition Windows

1) Édition supposée : Windows 10/11 Entreprise ou Éducation — seules éditions où AppLocker (domaine 13) est pleinement pilotable par GPO.

2) Si les 180 postes sont en édition Professionnel : réponse technique — basculer sur Windows Defender Application Control (WDAC, disponible en Professionnel) ou, à défaut, sur les Software Restriction Policies, en renforçant le retrait des droits d'administration locale (étape 20) ; réponse contractuelle — documenter l'écart comme demande de budget (migration vers Windows Entreprise via M365 E3/E5), cf. fiche d'écart résiduel section 8.

Q C.5 — Preuve d'exécution

Chaque étape appliquée doit être accompagnée de la sortie de sa commande de vérification, insérée en annexe (section 9) dans l'ordre des étapes retenues. Une étape sans capture n'est pas considérée comme appliquée.

5. Variante T1 — poste de Karim T.

Écarts par rapport au T2 ; toute étape non mentionnée est appliquée à l'identique.

Étape ajoutée/modifiée	En quoi elle diffère du T2	Justification
01-03 — comptes admin	Compte nominatif de Karim rattaché à un groupe AD délégué (« Admins-Serveurs-Fichiers ») avec élévation tracée.	Ses élévations doivent être traçables individuellement.
Domaine 8 — pare-feu sortant	Blocage sortant par défaut, sauf flux explicitement autorisés (RDP/WinRM vers les serveurs administrés, HTTPS via proxy).	N'a besoin d'atteindre que son périmètre, pas tout Internet.
Domaine 9 — audit	Journalisation transférée en temps réel au SIEM (Windows Event Forwarding).	Poste à capacité de pivot, à surveiller en continu.
Domaine 12 — accès distant	RDP sortant autorisé vers les serveurs uniquement via passerelle bastion/RDS ; RDP entrant toujours interdit.	Administration distante = cœur du métier, point de contrôle unique et journalisé.
Nouveau — séparation des usages	Deux comptes distincts : « karim.t » (bureautique) et « adm-karim.t » (serveurs), ce dernier n'ouvrant jamais de session mail/web.	Répond à Q0.2/QD.1 : évite qu'un identifiant à privilège soit exposé à un usage à risque.
Domaine 3 — LAPS	Pleinement applicable (poste réel joint au domaine).	Cf. Q C.1.

Q D.1 — De la pièce jointe piégée à la compromission des serveurs

Karim ouvre une pièce jointe piégée dans la session où il s'est authentifié (ou s'authentifiera) pour du RDP serveur. Le code capture ses identifiants/hash NTLM en mémoire (type LSASS dumping). L'attaquant rejoue ce secret pour ouvrir une session RDP légitime sur un serveur administré, puis accède aux données métier ou installe une porte dérobée. Toute la chaîne tient au même poste/session servant à la fois à un usage exposé (mail/web) et à un usage privilégié.

Q D.2 — Interdiction d'usage vs second poste dédié

Option	Coût	Contrainte d'usage	Sécurité
Interdire mail/web sur le poste actuel	Nul	Forte — perte d'accès habituel à la messagerie/doc	Fragile — pousse aux contournements (smartphone perso, webmail ailleurs)
Second poste dédié	Un poste à acheter/patcher/surveiller	Faible — poste bureautique complet conservé	Solide — séparation physique, difficile à contourner

Recommandation pour une DSI de 4 personnes : second poste dédié (ou station d'administration virtuelle isolée type PAW) — l'impact d'une compromission de l'unique administrateur systèmes serait disproportionné sans redondance possible ; le coût reste marginal face au risque.

Q D.3 — La mesure côté serveurs

Le cloisonnement ne tient que si les serveurs restreignent qui peut s'y connecter en RDP : droit « Autoriser l'ouverture de session par les services Bureau à distance » réservé au groupe admin serveurs, combiné à une règle pare-feu n'acceptant le RDP entrant que depuis l'IP du poste/bastion de Karim. Le mode Restricted Admin ou Remote Credential Guard évite en plus la mise en cache des identifiants sur le serveur distant.

6. Variante T0 — poste d'Élodie R.

Écarts par rapport au T1 ; toute étape non mentionnée est appliquée à l'identique.

Étape ajoutée/modifiée	En quoi elle diffère du T1	Justification
Domaine 8 — pare-feu sortant	Aucune route sortante vers Internet ; navigateur et client mail désinstallés.	Le compte peut prendre le contrôle total du SI — aucune exposition tolérée.
Domaine 3 — mot de passe admin	LAPS + authentification multifacteur matérielle (carte à puce / clé FIDO2).	Un mot de passe seul reste insuffisant pour ce niveau.

Étape ajoutée/modifiée	En quoi elle diffère du T1	Justification
Domaine 13 — AppLocker	Liste blanche réduite aux seuls outils d'administration AD/PKI/hyperviseur, signés ; aucun logiciel bureautique.	Le poste T0 n'a d'autre usage que l'administration du cœur du SI.
Nouveau — poste non nomade (PAW)	Poste physiquement fixe, dans un local sécurisé, jamais transporté.	Répond à Q0.2/QD.4 : un identifiant T0 ne doit jamais être exposé à un usage nomade.
Nouveau — isolation réseau	VLAN d'administration dédié, sans route vers le VLAN bureautique ni Internet.	Le poste T0 n'a besoin d'atteindre que DC, AC, hyperviseur, sauvegarde.
Domaine 9 — audit	Alerte temps réel sur toute session T0 échouée ou depuis un contexte inhabituel.	Un compte T0 compromis est l'incident le plus grave possible pour le SMEA.

Q D.4 — Pourquoi cette seule pratique annule tout le modèle

Le modèle repose sur un principe unique : un identifiant de niveau N ne doit jamais être exposé à un risque inférieur à N. Dès qu'Élodie relève sa messagerie « depuis n'importe où » avec le compte qui contrôle tout le SI, l'identifiant le plus puissant du syndicat est exposé au risque le plus large (phishing, wifi public, vol de portable). Peu importe alors que les 180 autres postes soient parfaitement durcis : un attaquant vise directement le maillon qui contrôle tout.

Q D.5 — Le dispositif quotidien d'Élodie

- Un poste T0 fixe, non nomade, en local sécurisé, sans navigateur ni messagerie — réservé aux DC, à l'AC interne, à l'hyperviseur et à la sauvegarde.
- Un poste bureautique T1/T2 portable distinct — messagerie, réunions, documents, déplacements ; celui qu'elle emporte réellement.
- Un moyen d'authentification dédié au poste T0 (carte à puce ou clé FIDO2) qui ne quitte jamais l'enceinte sécurisée.

Q D.6 — Le mécanisme technique de cloisonnement

Droits utilisateur « Refuser l'ouverture de session locale » et « Refuser l'ouverture de session par les services Bureau à distance », appliqués par GPO au groupe des comptes T0 sur les OU des postes T1/T2 (Configuration ordinateur → Paramètres de sécurité → Attribution des droits utilisateur). Mécanisme plus robuste : les silos d'authentification (Authentication Policies and Silos) AD, qui restreignent au niveau Kerberos les machines où un compte T0 peut s'authentifier — même mot de passe connu, le DC refuse le ticket hors silo.

7. Tableau de vérification avant / après

#	Point de contrôle	Avant	Après (T2)
1	SMBv1	Disabled	Disabled (conforme, étape 08)
2	Mdp/verrouillage	minpwlen=7, aucun verrouillage	minpwlen=14, verrouillage 5/15/15 (06-07)
3	Comptes locaux	Administrateur actif, « Admin » non tracé	Administrateur désactivé, AdminSMEA + nadia.b actifs (01-03, 20)
4	Groupe Administrateurs	Admin, Administrateur, groupes de domaine	AdminSMEA seul (03)
5	LmCompatibilityLevel	Non défini (niveau 3 implicite)	5 (09)
6	Pare-feu	Enabled, action NotConfigured, log off	Enabled, Block entrant, log actif (10)
7	Audit	Quelques sous-catégories	Ouverture session/comptes/objets/stratégie: Succès+Échec (11)
8	Ports en écoute	53, 88, 445, 3389, 5985, 9389…	Réduits au strict nécessaire ; 53 et 3389 fermés (13-14)
9	Fonctionnalités	DNS, AD DS, fichiers/iSCSI, RSAT…	Rôles superflus retirés, spouleur conservé/restreint (13)
10	Bureau à distance	fDenyTSConnections=0 (ouvert)	fDenyTSConnections=1 (fermé, 14)

Q E.2 — Ce qui a cassé

[À compléter avec votre propre exécution.] Incident le plus probable : étape 17 (Enforce AppLocker) si les règles de l'étape 16 sont incomplètes — la console PowerShell peut se retrouver bloquée, imposant une restauration de l'instantané apres-audit. Sur un poste réel en production, la mesure la plus susceptible de casser quelque chose est plutôt la désactivation de SMBv1 (08) si un équipement ancien ne parle qu'en SMBv1 — d'où l'intérêt de recenser ces équipements avant tout déploiement à grande échelle.

8. Fiches d'écart résiduel

Fiche 1 — Restriction d'exécution en édition Professionnel

Champ	Contenu
Référence	Domaine 13 — CIS 18.9.9 (AppLocker)
Mesure attendue	AppLocker en mode Enforce (nécessite édition Entreprise/Éducation)
Valeur retenue	Mode « Auditer uniquement » sur les 180 postes, actuellement en édition Professionnel
Justification métier	Absence de licence Windows Entreprise budgétée pour l'exercice en cours
Risque accepté	Exécution possible de binaires non autorisés en cas de compromission initiale
Mesure compensatoire	Retrait des droits d'admin locale (étape 20), restriction des dossiers inscriptibles, antivirus comportemental renforcé
Réévaluation	Prochaine campagne de licences ou obtention d'un budget dédié (cible : 12 mois)
Validation	RSSI / DSI du SMEA — signature à recueillir

Fiche 2 — Mot de passe administrateur local partagé pendant le déploiement LAPS

Champ	Contenu
Référence	Domaine 3 — mot de passe admin local unique (Windows LAPS)
Mesure attendue	Mot de passe unique et renouvelé automatiquement sur chaque poste
Valeur retenue	Mot de passe identique maintenu temporairement sur les postes non migrés
Justification métier	Déploiement LAPS nécessite une extension du schéma AD, hors plage de production
Risque accepté	Mouvement latéral possible entre postes non migrés en cas de compromission
Mesure compensatoire	Rotation manuelle trimestrielle documentée dans un coffre-fort DSI ; compte intégré désactivé (03) ; surveillance NTLM renforcée (11)
Réévaluation	Fin de la fenêtre de maintenance planifiée (cible : 3 mois)
Validation	RSSI / DSI du SMEA — signature à recueillir

Q E.4 — Industrialisation à 180 postes

Approche : image de référence (poste maître MDT ou Autopilot/Intune) pour la configuration initiale + GPO pour tout ce qui est pilotable nativement par AD + outil de gestion de configuration (Intune/Configuration Manager) pour le reste.

Automatisables : politique mdp/verrouillage (06-07), SMBv1 (08), LAN Manager (09), pare-feu (10), audit (11), UAC (12), retrait des rôles via l'image de référence (13), RDP/WinRM (14), règles AppLocker (16-17), mises à jour WSUS/Intune (19).

Manuels/semi-manuels : création du compte nominatif par technicien (01), vérification humaine avant désactivation du compte intégré (02-03), attribution du bon tier/OU par poste (décision humaine), séquestre BitLocker dépendant du TPM livré (18), recette finale avant mise en production.

9. Annexe — captures des sorties de vérification

Insérer, dans l'ordre des étapes 01 à 20 (section 4), une capture par étape montrant la commande de vérification et son résultat (Q C.5).

10. Sources et référentiels mobilisés

- CIS Microsoft Windows Server 2022 Benchmark, Center for Internet Security — cisecurity.org (préciser la version exacte utilisée, ex. v2.0.0)
- ANSSI, guides de configuration et recommandations de sécurité Windows — cyber.gouv.fr
- Documentation Microsoft Learn — Windows LAPS, AppLocker, BitLocker, silos d'authentification — learn.microsoft.com